

</ "img src="../../../frontend/assets/logo-lockup.svg" alt="Cornell Deep" width="300">

دليل الاختبار والتجربة — Cornell Deep · منصة حماية الهوية

الغرض: تجربة المشروع خطوة بخطوة واستعراض كل ميزة، مع جدول الحسابات الجاهزة

وأماكن الحصول على رموز OTP. بعد اتباع هذا الدليل تكون قد جرّبت:

التحقق من البريد، الجهاز الموثوق، السيناريوهات الثلاثة (S1/S2/S3)، الموافقة عبر جهاز آخر،

لوحة SOC كاملة، الهجمات المحاكاة A/B/C، بوابة المدرسة وRBAC، الاسترداد، والتحقق الرقمي.

(1) المتطلبات والتشغيل

- المتطلب: Node.js 24 أو أحدث فقط — لا حاجة لأي برامج أو قواعد بيانات أخرى.
- الخطوات:

```
npm install      # تثبيت الاعتماديات (مرة واحدة)
npm run db:reset  # قاعدة نظيفة وبيانات جاهزة (اختياري)
npm start        # تشغيل الخادم
```

افتح المتصفح على: <http://localhost:4000>

في الطرفية ستظهر رسالة تعرّف المستخدمين الجاهزين مع بريد Ethereum للمعاينة
(وعند غياب الإنترنت تُطبع رسائل البريد نصيًا هناك مباشرة).

(2) جدول المستخدمين الجاهزين (seed accounts)

تفاصيل كاملة من قاعدة البيانات (اسم الظهور، الدور، القسم، البريد، الهاتف):

اسم المستخدم	كلمة المرور	الدور	اسم الظهور	القسم	البريد الإلكتروني
student1	Student@123	طالب (STUDENT)	Sarah Chen	Computer Science	sarah.chen@campus.edu
student2	Student@123	طالب (STUDENT)	Omar Farouk	Computer Science	omar.farouk@campus.edu
teacher1	Teacher@123	معلم (TEACHER)	Dr. Elena Roberts	Information Security	elena.roberts@campus.edu

اسم المستخدم	كلمة المرور	الدور	اسم الظهور	القسم	البريد الإلكتروني
teacher2	Teacher@123	معلم (TEACHER)	Prof. Marcus Reid	Network Engineering	marcus.reid@campus.edu
admin	Admin@123	مشرف (ADMINISTRATOR)	Alex Morgan	IT Security Office	alex.morgan@campus.edu

ملاحظة: هذه الحسابات مثبتت كـ "جهاز موثوق" افتراضيًا بعد أول دخول؛
أي تسجيل دخول جديد من جهازك يُعامل وفق درجة الخطر (جديد +30، شبكة جديدة +25).

أين أجد رمز OTP الحي؟

شاشة الدخول تعرض لوحة DEMO تثبت رمز TOTP الحالي لكل حساب (يتجدد كل 30 ثانية). البديل: افتح <http://localhost:4000/api/identity/otps> في المتصفح لعرض نفس الرموز كـ JSON.

3) جولة شاملة خطوة بخطوة

الفصل 1 — دخول المشرف ولوحة SOC

- من شاشة الدخول اكتب `admin / Admin@123` واختر السيناريو 3.
- أدخل رمز OTP من لوحة DEMO، ثم الرمز الإضافي عبر البريد (أو من طباعة الطرفية عند غياب الشبكة).
- ستفتح لوحة SOC بتقسيمات: نظرة عامة، السجل، الجلسات، الأجهزة، العوامل، القوائم، المحاكاة.
- جرب التبويبات وراقب العدادات وهي حية (بـ SSE — أي حدث يظهر فورًا دون تحديث).

الفصل 2 — سيناريو 1 (كلمة المرور فقط) لطالب

- سجل خروجًا ثم ادخل بـ `student1 / Student@123` والسيناريو 1.
- لأن السياق منخفض الخطر → دخول مباشر.
- في مركز الأمان الشخصي شاهد: أجهزتك الموثوقة، جلساتك، نشاطك، ودرجة وضعك الأمني.

الفصل 3 — سيناريو 2/3 مع خطوة OTP

- ادخل بـ `teacher1 / Teacher@123` والسيناريو 2.
- سيطالبك النظام برمز OTP (السيناريو 2) — خذه من لوحة DEMO وأكمله.
- جرب السيناريو 3 وتحقق أنه يطلب OTP + بريد معًا.
- أدرك الفرق: السيناريو هو الطلب اليدوي، لكن درجة الخطر التكميلية تُضيف خطوات إضافية تلقائيًا.

الفصل 4 — تسجيل حساب جديد وتفعيل الجهاز الموثوق

- من شاشة الدخول اضغط **Create account** / سجل.
- املأ: اسم، بريدًا بصيغة صحيحة (مثل `myname@gmail.com`)، رقمًا وطنيًا، وكلمة مرور ≥ 8 .
- بعد الإنشاء ستجد في الطرفية/الرد رابط التحقق مع معاينة **Ethereal**.
- اضغط «أنشئ» ثم «Verify now في هذا المتصفح» ← صفحة «Email verified ✓».

5. النتيجة: هذا المتصفح صار جهازًا موثوقًا — ادخل الآن بنفس الحساب والسيناريو 1 → دخول مباشر بلا أي خطوة.

الفصل 5 — الموافقة عبر جهاز آخر (Cross-Device Approval)

1. افتح نفس رابط المشروع في نافذة تصفّح خفية (Incognito).
2. ادخل بحسابك المسجّل آنفًا، السيناريو 2.
3. في المتصفح الموثوق ستظهر فورًا نافذة «موافقة على دخول خارجي» (الجهاز، IP، الأسباب، درجة الخطر).
4. اضغط **Approve** يكتمل الدخول في النافذة الخفية؛ أو **Deny** لرفضه.
5. جرّب بعدها إغلاق الجهاز الموثوق (أو الانتظار ~20 ثانية) → يتحول الطلب تلقائيًا إلى بريد + OTP.

الفصل 6 — تشغيل الهجمات المحاكاة (الأداء المشهدي)

من لوحة المشرف (SOC) → تبويب **Attack Simulation**:

- **Type A (Brute Force)**: محاولات كلمات مرور خاطئة → لاحظ تصاعد درجة الخطر حتى الإقفال.
 - **Type B (Impossible Travel)**: دخول من الرياض ثم سان فرانسيسكو → 40+ → إقفال.
 - **Type C (Credential Stuffer)**: دخول من عنوان مدرج في القائمة السوداء → حظر.
- راقب: الخط الزمني اللحظي بالأسفل، توزيع الدرجات في النظرة العامة، وعدّادات النجاح/الفشل.

الفصل 7 — القائمة السوداء/البيضاء

1. في تبويب **Blacklist** أضف أي عنوان مثل 31.13.99.5.
2. أي محاولة دخول لاحقة من هذا العنوان تُرفض فورًا حتى بكلمة مرور صحيحة (+45).

الفصل 8 — بوابة المدرسة و RBAC (مصفوفة الصلاحيات)

- ادخل بـ **student1** → تبويب البوابة: مقرراته ودرجاته وحضوره فقط؛ الوصول لقوائم صفية أو دليل مستخدمين مرفوض (403).
- ادخل بـ **teacher1** → البوابة تعرض مقرراته وقوائم صفوفه فقط.
- ادخل بـ **admin** → البوابة كاملة + مصفوفة الصلاحيات 3×8 تُعرض أمامك.

الفصل 9 — استرداد الحساب وإعادة ضبط MFA

1. من مركز الأمان الشخصي اختر الاسترداد/إعادة ضبط MFA.
2. اتبع **request → reset → validate**: رمز تحقق → تدوير سر TOTP + كلمة مرور جديدة → 10 رموز استرداد أحادية الاستخدام.
3. جرّب بعدها الدخول بسرّ TOTP الجديد، ولاحظ تسجيل العملية في سجل المشرف.

الفصل 10 — التحقيق الرقمي (Forensics)

1. من لوحة المشرف افتح **Forensics**.
2. ابحث عن مستخدم (مثل **student1**) → خط زمني معاد بناؤه بالكامل.
3. أنشئ قضية (Case) نقرة واحدة → تتجمع الأدلة تلقائيًا → صُدّر الأدلة **Markdown** للأرشفة.

الفصل 11 — البنشمارك (مقارنة الأداء)

من التبويب نفسه اعرض **Benchmark**: عدد محاولات كل سيناريو (S1/S2/S3)، متوسط زمن الدخول (من `elapsed_ms` الحقيقي)، وعدّادات النجاح — مقارنة مرئية لتكلفة التحقق الإضافي.

الفصل 12 — البتّ الحي (نافذتان معًا)

1. اترك لوحة المشرف مفتوحة على تبويب **Overview**.
2. في نافذة أخرى سجّل دخولًا (أو شغّل هجومًا محاكي) → شاهد الحدث يظهر فورًا في الأولى.

الفصل 13 — بقاء البيانات بعد إعادة التشغيل (NFR)

1. حدث بيانات (أجهزة/جلسات/قضايا/هجمات).
2. أوقف الخادم (**Ctrl+C**) ثم شغّله من جديد.
3. ادخل كالمشرف وتأكد أن كل البيانات ما زالت موجودة (تخزين SQLite دائم).

الفصل 14 — الاختبار الآلي الكامل (140 فحصًا)

إيقاف الخادم أولًا ثم:

```
node scripts/reset-db.js      # قاعدة نظيفة
npm start                     # تشغيل الخادم
node scripts/smoke.js         # 17
node scripts/e2e-all.js      # 77
node scripts/ui-smoke.js      # 28
node scripts/restart-check.js # 18 (يستخدم منفذًا منفصلًا: 4001)
```

المتوقع: كل سكربت ينهي بـ ☒ وتقرير «ALL PASS» —المجموع 140 أخضر.

4) كيف ترفع درجة الخطر يدويًا؟ (لاختبار كل مستوى)

النتيجة	افعل	تريد إثارة العامل
درجة أعلى ودخول يتطلب خطوة إضافية	سجّل الدخول من 07:00 إلى 23:00	F_TIME_ANOMALY (+15)
درجة تضاف	ادخل من بوابة / شبكة مختلفة	F_NEW_IP (+25)
درجة تضاف ويطلب OTP/موافقة	ادخل من متصفح/جهاز غير موثوق (خفية)	F_NEW_DEVICE (+30)
خطر 95~ وإقفال فوري	شغّل الهجوم Type B من لوحة المشرف	F_IMPOSSIBLE_TRAVEL (+40)
خطر فوري حتى بصحة الباسورد	أدرج عنوانك في القائمة السوداء ثم ادخل	F_BLACKLISTED_IP (+45)
إقفال تلقائي بعد الثانية	أدخل كلمة مرور خاطئة مرتين متتاليتين	F_CONSECUTIVE_FAILURE (+20×)

إطلاق الإقفال: من لوحة المشرف → **Force unlock** → Threat Factors للمستخدم المعني.

5) قائمة فحص الميزات (قم بوسمها أثناء التجربة)

#	الميزة	كيف تجربها	✓
1	تسجيل + تأكيد بريد حقيقي	الفصل 4	☐

#	الميزة	كيف تجربها	✓
2	الجهاز الموثوق (كوكي سنة)	الفصل 4 / <code>api/me</code>	☐
3	سيناريو 1 (باسورد فقط)	الفصل 2	☐
4	سيناريو 2 (OTP)	الفصل 3	☐
5	سيناريو 3 (OTP + بريد)	الفصل 3	☐
6	درجة الخطر ونطاقات LOW/MEDIUM/HIGH	الفصل 4 / 2	☐
7	الموافقة عبر جهاز آخر (fallback+)	الفصل 5	☐
8	لوحة SOC وبتّ SSE الحي	الفصل 1 / 12	☐
9	هجمات A/B/C وعدّادات حيّة	الفصل 6	☐
10	قوائم بيضاء/سوداء	الفصل 7	☐
11	بوابة المدرسة (8×3) RBAC وحماية 403	الفصل 8	☐
12	مصفوفة الصلاحيات للمشرف	الفصل 8	☐
13	الاسترداد + 10 رموز استرداد	الفصل 9	☐
14	التحقيق الرقمي + قضايا + تصدير	الفصل 10	☐
15	البنشمارك (مقارنة الأزمنة)	الفصل 11	☐
16	بقاء البيانات بعد إعادة التشغيل	الفصل 13	☐
17	الاختبار الآلي (140 أخضر)	الفصل 14	☐

(6) أسئلة وأخطاء شائعة

أين رمز OTP؟ لوحة DEMO في شاشة الدخول، أو `http://localhost:4000/api/identity/otps`. الرمز يتجدد كل 30 ثانية — إن انتهى انتظر الرمز التالي.

لماذا لا يصل البريد؟ التطبيق يستخدم Ethereum؛ امنح رابط المعاينة الذي يظهر. بدون إنترنت تُطبع الرسالة في الطرفية (وضع `mail-degraded`).

أدخلت رمز OTP خاطئاً؟ لا يُقفل الحساب (القفل للباسورد المتكرر فقط)؛ أعد المحاولة برمز جديد.

ماذا يعني 401 مقابل 403؟ 401 = لا توجد جلسة/لم تُسجّل الدخول؛ 403 = أدخلت بنقاش ناقص للصلاحيّة.

هل هذه منصة إنتاج حقيقية؟ مشروع تعليمي/استعراضي يحاكي آليات الدفاع؛ لا تستخدمه للبيانات الحساسة دون مراجعة أمنية.